

# Network and Computer Security — Lecture 10

Dr. Karim Lounis

Jan - Jun 2026



# Part 3

## Network Security

# Computer Networks and Network Security

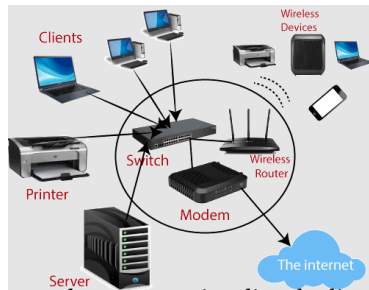
## Definition

**Computer Network.** Is a network (set of nodes) that connects together computers that are physically situated at different locations, for communication, cooperation, and information sharing.

It has the following features:

- Computer network has physical (e.g., devices, computers, wires, antennas, etc), logical (e.g., connections, files, database, etc), and social (e.g., staff, security engineers, etc) resources.
- Each resource is subject to be compromised by malicious parties via attacks.

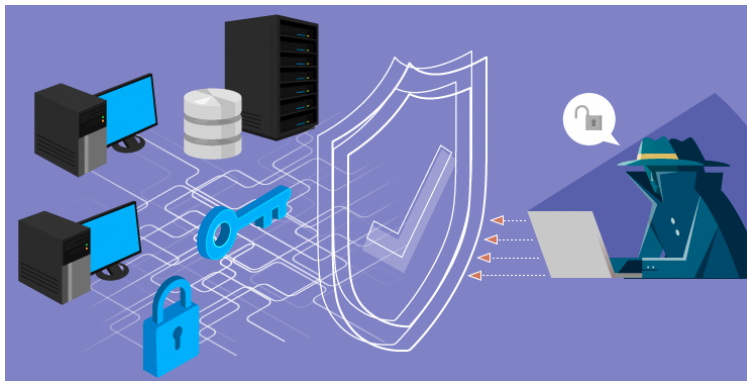
Providing and ensuring security for computer network resources implies dealing carefully with the topic of network security.



# Computer Networks and Network Security

## Definition

**Network Security.** Is a computing discipline that studies how to protect computer networks from security threats.

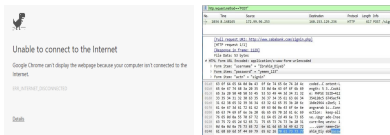




# Network Security (Recall: Network Security Aspect)

Implies securing many of components — logical, physical, and social too:

- Use security protocols to secure network traffic, devices, users...
- Physically protect network devices (e.g., routers, gateways, servers, access points, etc), cables, radio antennas, and the radio bands.
- Use security applications (or appliances) such as event loggers, firewalls, intrusion detection/prevention systems, etc.
- Follow recommended secure device configuration patterns.
- Stop using insecure protocols and upgrade to latest versions.
- Throw away old and no-longer supported network devices.
- Secure server rooms (locks, camera, alarm + cleaning, etc).
- Do not plug network devices without authorization (e.g., Lan Turtle).



# Network Security Devices (Tools)

# Firewall

## Definition

**Firewall.** Is a security system (software or appliance) designed to receive, analyze, monitor, (sometimes, modify), and/or filter incoming (and sometimes outgoing) network traffic based on predetermined rules.

It has the following features:

- It typically establishes a barrier between a trusted internal network and an untrusted external network (like the Internet).
- It blocks unwanted network traffic and permits wanted network traffic.
- Hackers from outside (Fire) will try to break into your private network and compromise it (spread fire inside).

The firewall will block the fire from spreading over you network.

Filtering network traffic is based on rules — Access Control List, which for a given IP address (source and destination), communication port, and communication protocol, decides whether to **ALLOW** or **DENY** access.



# Firewall (Class of Firewall)

## Definition

**Firewall.** Is a security system (software or appliance) designed to receive, analyze, monitor, (sometimes, modify), and/or filter incoming (and sometimes outgoing) network traffic based on predetermined rules.

There are two main classes of firewall:

- ① **Host-based firewall.** This is a software installed as part of the operating system. E.g., Microsoft Windows Defender firewall, and iptables, ufw, shorewall, IPFire, and firewalld on Linux systems.
- ② **Network-based firewall.** A network device, either a stand-alone device, or a built-in software module in the router/gateway, that is placed between the private network and the Internet.

The network-based firewall can also be deployed as a service by a cloud service provider (FWaaS). E.g., AWS, Palo Alto Cloud NGFW, etc.

# Firewall (Type of Firewall)

There are six types of firewall:

- ① **Packet-filtering firewall (87-)**. They analyze the headers of TCP segments, UDP datagrams, and IP packets to decide whether to forward or drop them based on a set of criteria (i.e., ACL).

Limited context awareness, no session awareness (stateless), vulnerable to IP spoofing (bypass firewall) and other attacks

- ② **Stateful inspection firewall (89-)**. They keep track of packets from established sessions (stateful — keep track of active connections using state table) and inspect packets' header information.

Latency, cannot detect insider attacks and certain social engineering attacks

- ③ **Application-level gateway (93-)**. A.k.a., proxy firewall. It performs in-depth packet inspection (content of packets — apps, URLs, etc) and control. It acts as a forward-proxy (user auth, caching, etc).

Additional latency, more resources, configuration and maintenance, and cannot detect insider and certain SE attacks.

# Firewall (Type of Firewall)

There are six types of firewall:

- ④ **Web Application firewall (02-)**. Specifically protects web apps by filtering HTTP/HTTPS traffic, blocking SQL injections, XSS, CSRF, and many other web malicious payloads.

Restricted to web applications

- ⑤ **Next generation firewall (12-)**. Combines packet inspection, stateful inspection, deep-packet inspection (DPI), intrusion detection, malware filtering, spam filtering, and anti-virus (or IDS/IPS).

Cannot detect insider and SE attacks

- ⑥ ?

# Firewall (Type of Firewall)

There are six types of firewall:

- ④ **Web Application firewall (02-)**. Specifically protects web apps by filtering HTTP/HTTPS traffic, blocking SQL injections, XSS, CSRF, and many other web malicious payloads.

Restricted to web applications

- ⑤ **Next generation firewall (12-)**. Combines packet inspection, stateful inspection, deep-packet inspection (DPI), intrusion detection, malware filtering, spam filtering, and anti-virus (or IDS/IPS).

Cannot detect insider and SE attacks

- ⑥ **Human firewall**. It aims to protect an organization from cyberattacks through human intervention. Employees are trained to identify suspicious content, follow security best practice, etc.

Constant education and human errors.

## Firewall (Examples — iptables on Linux-based systems)

Firewalls play a critical role in safeguarding your network by filtering incoming and outgoing traffic based on predefined security rules.

- **iptables.** On Linux systems, **iptables** is a user-space command line tool to configure Linux firewall **Netfilter**:

```
$ iptables -t filter -I INPUT -s 192.114.2.2 -j DROP
```

```
$ iptables -t filter -I FORWARD -s 192.114.2.2 -j DROP
```

Block (-j DROP) all traffic from IP address 192.114.2.2 from connecting to your internal network/local computer.

```
$ iptables -I INPUT -p tcp --dport 22 -s 10.80.1.5 -j ACCEPT
```

```
$ iptables -I INPUT -p tcp --dport 22 -j DROP
```

Allow only SSH traffic from trusted IP 10.80.1.5

Note that **-t filter** is optional. It is the default table.



# Firewall (Examples — iptables on Linux-based systems)

Firewalls play a critical role in safeguarding your network by filtering incoming and outgoing traffic based on predefined security rules.

- **iptables.** On Linux systems, **iptables** is a user-space command line tool to configure Linux firewall **Netfilter**:

```
$ iptables -t nat -I PREROUTING -p tcp -d @ --dport 443 -j DROP
```

This inserts (-I) a new rule into the **nat** iptable to block (-j DROP) **tcp** incoming traffic going to secure web services running on a host whose IP address is **@** (stop bad traffic as early as possible).

```
$ iptables -t nat -I POSTROUTING -o eth0 -j MASQUERADE
```

The machine is acting as a router of the LAN 192.168.1.0/24, connecting it to Internet through **eth0**. So, all packets leaving to Internet get their source IP address natted to the public IP address.

# Firewall (Examples — iptables on Linux-based systems)

Firewall **iptables** can be seen as a series of interconnected chains. Each chain groups rules that inspect packets based on specific criteria:

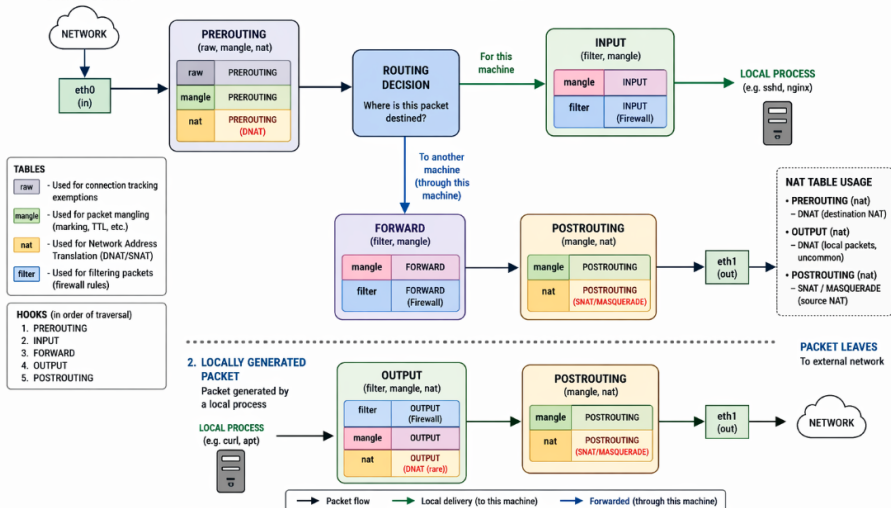
- **INPUT:** Packets destined for the local machine itself are inspected here (as they arrive at the network interface).
- **OUTPUT:** Packets generated by local processes are inspected here before they are sent out (as they leave the NIC).
- **FORWARD:** Packets that need to be forwarded to another machine on the network pass through this chain.
- **PREROUTING:** This chain is part of the NAT (Network Address Translation) table. It is invoked before the Linux kernel performs the routing decision (i.e., consumes or forwards).
- **POSTROUTING:** This chain is also part of the NAT table. It is invoked after the routing decision has been made and just before the packet is sent out on the wire (or radio).

# IPTABLES / NETFILTER PACKET FLOW

Linux Kernel Packet Path

## 1. INCOMING PACKET

Packet arrives on a network interface



## KEY TAKEAWAY

Packets do not go through tables in sequence. They traverse hooks (PREROUTING → routing decision → INPUT/FORWARD → OUTPUT → POSTROUTING), and at each hook multiple tables (raw, mangle, nat, filter) may process the packet.

## Firewall (Examples — ufw on Linux-based systems)

Firewalls play a critical role in safeguarding your network by filtering incoming and outgoing traffic based on predefined security rules.

- **ufw.** On Linux systems, **uncomplicated firewall** is a firewall for the Linux kernel that allows granular control over network traffic. It is managed through CLI or Gufw interface to define filtering rules:

```
$ ufw default deny incoming
```

```
$ ufw default allow outgoing
```

These create filtering policies (i.e., rules) that block all incoming connections and allow all outgoing connections.

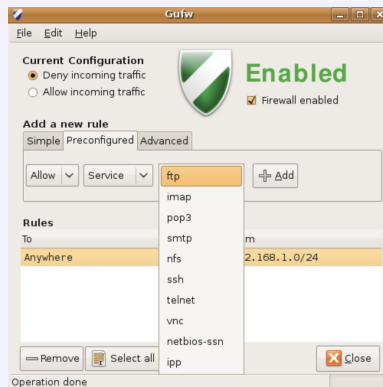
```
$ ufw allow from IP@ to any port ssh
```

This creates a policy to allow ssh connections to the local computer only from a specific remote IP@.

You may want to check the status of the firewall: `$ ufw status`

# Firewall (Examples — ufw on Linux-based systems)

Firewalls play a critical role in safeguarding your network by filtering incoming and outgoing traffic. In this section, we will explore the ufw GUI, a.k.a., Gufw:

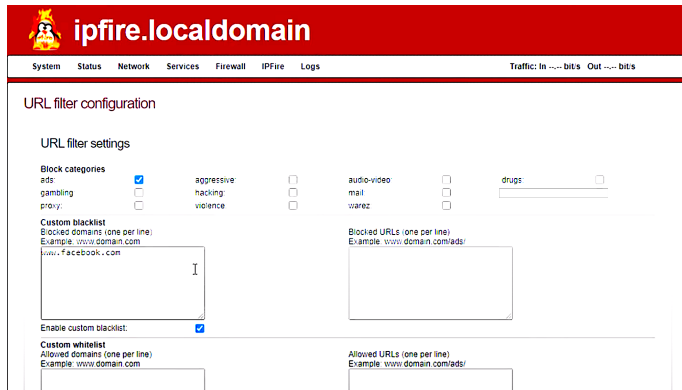


You The ufw is designed as a user-friendly interface for iptables.

# Firewall (Examples —IPFire on Linux-based systems)

Firewalls play a critical role in safeguarding your network by filtering incoming and outgoing traffic based on predefined security rules.

- **IPFire.** IPFire is a firewall for Linux systems. It is mainly managed through web interface to define filtering rules:



The screenshot displays the IPFire web interface for a local domain. The top navigation bar includes links for System, Status, Network, Services, Firewall, IPFire, and Logs. A traffic status indicator shows 'In ---- bit/s' and 'Out ---- bit/s'. The main content area is titled 'URL filter configuration' and contains 'URL filter settings'. Under 'Block categories', there are checkboxes for 'ads' (checked), 'gambing', 'proxy', 'aggressive', 'hacking', 'violence', 'audio-video', 'mail', 'warez', and 'drugs'. Below this, there are two text input fields for 'Blocked domains (one per line)' and 'Blocked URLs (one per line)', both containing example text. The 'Enable custom blacklist' checkbox is checked. At the bottom, there are two more text input fields for 'Allowed domains (one per line)' and 'Allowed URLs (one per line)', both containing example text. The interface is clean and functional, with a red header and a white body.

# Firewall — DMZ (Demilitarized Zone)

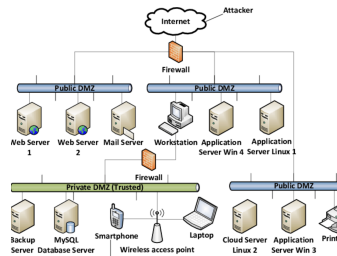
## Definition

**DMZ.** Is a network typically exposing public services, e.g., web, DNS, DB, FTP, or mail servers, in a subnetwork separated from the internal network of a company. It aims at protecting internal resources while providing services to untrusted networks, e.g., the Internet.

It has the following features:

- The essential element to control this segmentation is the **firewall**.
- The basic firewall deployment architecture to set a DMZ is based on a two-tier design.
- Other DMZ designs use one-tier architecture (i.e., one firewall with 3 NICs).

We can add even more security by employing two different firewall vendors (**Guess why?**).



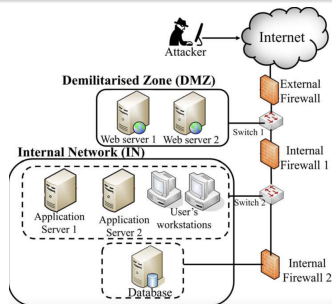
# Firewall — DMZ (Demilitarized Zone)

## Definition

**DMZ.** Is a network typically exposing public services, e.g., web, DNS, DB, FTP, or mail servers, in a subnetwork separated from the internal network of a company. It aims at protecting internal resources while providing services to untrusted networks, e.g., the Internet.

It has the following features:

- The essential element to control this segmentation is the **firewall**.
- The basic firewall deployment architecture to set a DMZ is based on a two-tier design.
- Other DMZ designs use one-tier architecture (i.e., one firewall with 3 NICs).
- We can add even more security BY employing two different firewall vendors so an exploit found in one is unlikely to be present in the other.





# Intrusion Detection Systems

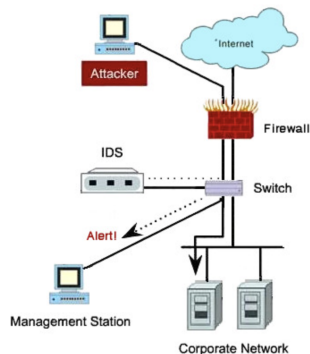
## Definition

**IDS.** Is a device or software application that monitors systems (computer or network) for malicious activities (behavior) and/or content (signature), and notifies (alarms) the system administrator about it.

It has the following features:

- Intrusion detection systems can be a host-based IDS (HIDS), a network-based IDS (NIDS), or a wireless IDS (WIDS).
- Can be passive (detect and alert) or active (detect, alert, and attack back). Active IDSs are no longer considered legal.
- Traditionally, IDS are used to monitor network traffic (or system events) for suspicious signs or behaviors. If detected, IDS notifies the system administrator.

Known IDSs: Snort, Snort-Wireless, Suricata, OSSEC, Tripwire, Kismet, etc.



# Intrusion Detection Systems

## Type of IDS:

- **Signature-based IDS.** Compares network traffic or system activity against a predefined database of malicious signatures or attack patterns and trigger an alert when a match is discovered.
  - It may detect denial of service attacks — smurf, ping of death, deauthentication, IP spoofing, session hijacking, etc.
  - They are reliable in detecting known attacks
  - Can't detect zero-day attacks and requires constant update of the database (to contain the latest signatures)
- **Behavior-based IDS.** A.k.a., anomaly-detection. It establishes a baseline (model) of normal behavior for network traffic or system activity. Then, it monitors the system (i.e., events, packets, context, ...) to identify any deviations from the model.
  - It may detect that a user, who typically logs in during business hours, attempts to access at 3AM, that a program is accessing unauthorized resource, or detect a sudden spike in network traffic.
  - Can potentially detect zero-day attacks
  - Can generate a high number of false positive.

# Intrusion Detection Systems

Another type, called hybrid-IDS, which combines both signature-based and anomaly-based mechanism.

An IDS, generally, consists of four main components:

- ① The sensors, which are components responsible for monitoring system events and network traffic. In NIDS, they are often called drones.
- ② A database of malicious signatures or behavioral-model.
- ③ The IDS engine, which analyses the system event and network traffic and compares that against the database (of signature or model).
- ④ The admin interface, which is responsible for notifying the network administrator about possible intrusions when they are detected.

Modern IDSs use artificial intelligence — machine learning techniques — to develop and train a model over normal behavior (user activity or network traffic).

If the training process is compromised, the intrusion detection system will be compromised too.

# Intrusion Detection Systems (FPs and FNs)

An intrusion detection system allows for continuous monitoring of network activities to detect possible intentional or unintentional intrusion attempts. One of the challenges that IDSs face is the concepts of false positives and negatives:

- **False Positives.** A false positive occurs when an IDS triggers an alert for an event that's actually legitimate activity.
  - IDS rules are too broad and not fine-tuned.
  - Unusual but legitimate network traffic spikes.
  - Errors in IDS rule configuration.
- **False Negatives.** A false negative occurs when an IDS fails to detect a real security threat. This can be a serious security issue as an attack can go unnoticed and potentially cause damage.
  - Attackers used new techniques and signatures.
  - IDS might not have complete visibility.
  - Lack of proper tuning or resource limitations.

There are also true positives and true negatives.

## Intrusion Detection System (Example)

In the case of signature-based IDSs, we generally define rules to analyze packets and triggers alerts when the rule is broken:

- **Snort** operates on Layer 3 and 4. We can use it to detect SYN flood attack against our ssh server (attack from LAN):

```
alert tcp $HOME_NET any -> $HOME_NET 22
```

```
(msg: "SYN Flood Detected on port 22";
```

```
flags:S; flow:stateless;
```

```
detection_filter: track by_dst, count: 40, seconds: 10;
```

```
classtype:attempted-dos; action: [log, alert, etc])
```

You can configure log monitoring tools, e.g., **Swatch**, to monitor **snort's** logs and take specified actions whenever a match occurs, e.g., trigger an alarm, send email, or send sms to network/system administrator.

# Intrusion Detection System (Example)

In the case of signature-based IDSs, we generally define rules to analyze packets and triggers alerts when the rule is broken:

- **Snort** operates on Layer 3 and 4. We can use it to detect Ping of Death attack against the local network:

```
alert icmp any any -> any any
```

```
(msg: "Ping of Death Detected";
```

```
icmp_type:echo; icmp_code:0; icmp_length:>65535;
```

```
flow:stateless; classtype:attempted-dos;)
```

You can configure log monitoring tools, e.g., **Swatch**, to monitor **snort's** logs and take specified actions whenever a match occurs, e.g., trigger an alarm, send email, or send sms to network/system administrator.

# Intrusion Detection System (Example)

In the case of signature-based IDSs, we generally define rules to analyze packets. **Exercise.** Analyze the following snort rule and say which network attack the rule may be used for:

```
alert icmp any any -> 10.0.0.0/8  
(msg: "Possible XXXXX Attack Detected";  
  icmp_type:echo; count:100; seconds:10  
  flow:stateless; classtype:attempted-dos;)
```

You can configure log monitoring tools, e.g., Swatch, to monitor snort's logs and take specified actions whenever a match occurs, e.g., trigger an alarm, send email, or send sms to network/system administrator.

# Intrusion Detection System (Example)

In the case of signature-based IDSs, we generally define rules to analyze packets. **Exercise.** Analyze the following `snort` rule and say which network attack the rule may be used for:

```
alert icmp any any -> 10.0.0.0/8
(msg: "Possible XXXXX Attack Detected";
 icmp_type:echo; count:100; seconds:10
 flow:stateless; classtype:attempted-dos;)
```

The rule can be used to detect SMURF Attack within the local network 10.0.0.0/8. It triggers the rule when `snort` detects 100 ping requests within 10 seconds.



# Intrusion Prevention Systems

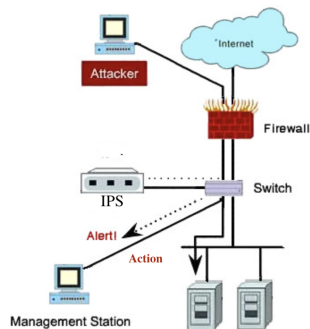
## Definition

**IPS.** Is a device or software application that monitors systems (computer or network) for malicious activities (behavior) and/or content (signature), notifies (alarms) the system administrator about it, and take steps to block or otherwise prevent the escalation of an intrusion.

It has the following features:

- Intrusion prevention systems can be a host-based IPS (HIPS), a network-based IPS (NIPS), or a wireless IPS (WIPS).
- Can be passive (detect, alert, and prevent) or active (detect, alert, prevent, and counterattack). Active IPSs are not legal.

Known IPSs: Cisco Firepower NGFW, McAfee Enterprise security manager, FortiGate Next-Generation Firewalls, etc.



# Honeypots

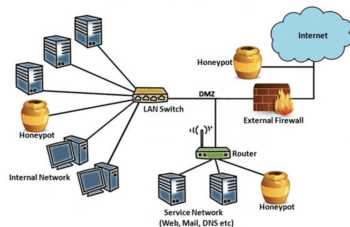
## Definition

**Honeypot.** Is a networking “decoy” device (deliberately left with various vulnerabilities) designed to attract and lure cyber attackers to launch an attack against it (it could be an entire network). It logs all events to learn the tactics and techniques used by attackers (modern approaches).

It has the following features:

- Honeypots are designed to appear like legitimate targets to attackers. They might mimic services, login pages, etc.
- This could involve offering enticing fake data like financial records.
- Using honeypots might raise **legal concerns** in some jurisdictions (e.g., entrapment).

The information gathered from honeypot interactions helps security teams improve their overall defenses.



# Proxy Servers

## Definition

**Proxy server.** Is an intermediate server that acts as a gateway between a user's computer and the Internet (i.e., web-sites or web-services).



Instead of connecting directly to a website or other Internet resources, the user's computer first connects to the proxy server, and then the proxy server connects to the destination (website or web-service) on behalf of the user. Also, note that there are **forward proxies** and **reverse proxies**.

# Proxy Servers

**Proxy server.** Is an intermediate server that acts as a gateway between a user's computer and the internet (i.e., web-sites or web-services).

Proxies can be used for various purposes:

- ① **Bypassing Geo-restrictions.** If the user is blocked from directly accessing a website, they can go through the proxy to access that website..
  - If the country hosting a website is blocking some src IPv4 addresses, but allowing some proxies (installed in their or allies lands).
  - If a country is blocking access to some websites, but allowing proxy connections (Access to website will be established in a **tunnel**).
- ② **Proxy DNS.** Instead of using the ISP's servers, you could configure your own DNS server at home (e.g., using piHole and OpenDNS) to protect your families. This would allow you to perform:
  - Content Filtering and Access Control.
  - Caching proxy servers can store copies of frequently accessed resources locally, reducing the need to fetch them from the Internet each time.

# Proxy Servers

**Proxy server.** Is an intermediate server that acts as a gateway between a user's computer and the internet (i.e., web-sites or web-services).

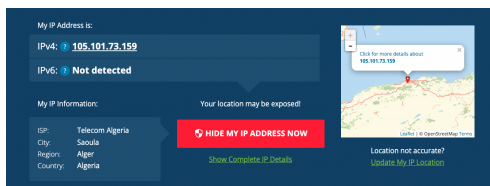
Proxies can be used for various purposes:

- ③ **Improving Security.** Proxies can be used to implement **VPNs** (Virtual Private Networks), i.e., secure communication tunnels.
  - Proxy servers can act as an additional layer of security, inspecting and filtering incoming and outgoing traffic for malicious content.
  - They can be part of a defense-in-depth strategy to protect against various online threats.
- ④ **Enhancing Privacy and Anonymity.** Users can use proxy servers to hide their IP addresses and enhance their online privacy (where users don't want their identity or location to be easily traced).
  - Use **VPN** client software, e.g., HotSpot Shield, Tor Browser, etc.
- ⑤ **Load-Balancing.** Reverse proxy servers can distribute incoming network traffic across multiple servers to ensure that no single server is overwhelmed (e.g., try `$ nslookup www.youtube.com`).

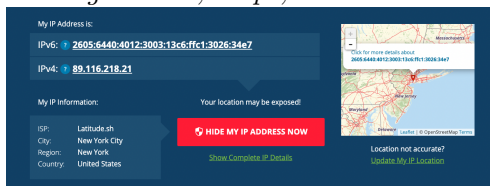
# Proxy Servers

**Proxy server.** Is an intermediate server that acts as a gateway between a user's computer and the Internet (i.e., web-sites or web-services).

This is an example of using HostSport Shield VPN client software:



*We got them, Oops, We lost them*



- **End.**